

StarBridge Portal（虚构样例）安全审查报告

https://github.com/example/starbridge-portal · branch main · commit demo-9f4a2c1 · 生成时间 2026-05-13T21:07:44+08:00

严重
总体风险

77.0
总体得分

100.0%
覆盖率

25
风险发现

47
存疑

执行摘要

StarBridge Portal（虚构样例）展示了一类多租户 SaaS 常见的组合风险：对象级授权缺失、Webhook 签名缺失、报表过滤拼接 SQL、链接预览 SSRF、导出下载路径遍历、批量赋值、支付回调伪造、前端 Token 存储、硬编码密钥、对象存储公开、CI 权限过大、数据库公网暴露以及 AI 成本滥用。该报告仅用于展示 Skill 的评分表、证据组织和多格式输出能力。

范围与授权

授权：示例报告，不对应真实授权目标；所有系统名称、仓库地址、代码路径、端点、账号、证据和漏洞均为虚构。

范围：公开示例报告：虚构 SaaS 协作平台，所有端点、文件路径、风险发现和测试证据均为演示内容。

覆盖说明：本报告用于演示格式，不可作为真实系统安全结论。若套用到真实项目，需要重新克隆/部署目标并重新填充证据。

审查方法与覆盖

字段	值
环境	虚构 GitHub 仓库 + 隔离临时运行环境
审查模式	动态安全审查
测试强度	低风险运行时
源码隔离	示例假设目标代码已克隆到全新临时目录；所有构建、运行、测试和报告生成都发生在隔离目录内。
允许的动态测试	runtime-check passive-dast
OOB 端点	
限速边界	演示数据：每个端点最多 3 次请求，不执行循环爆破。
回滚/数据重置	删除临时目录即可回滚。/ 临时 SQLite/PostgreSQL 数据均为虚构演示数据，可直接丢弃。
排除范围	未执行真实线上探测、真实 OOB、真实暴力破解、真实文件破坏、真实生产数据库写入或真实第三方服务调用。
攻击面	虚构的 StarBridge Portal 是一个多租户内容协作 SaaS：包含账号登录、团队空间、文档管理、导入导出、Webhook、订阅计费、前端 SPA、对象存储、PostgreSQL/Redis、Docker Compose 和 AI 摘要能力。
选定风险域	访问控制与租户隔离 认证与会话 API 与业务逻辑 SSRF/链接预览 文件上传与导出 前端浏览器安全 供应链与 CI/CD 云网络与数据库 AI/RAG 安全
不适用判定依据	虚构样例不包含 LDAP、SAML、SOAP/XML、GraphQL、Kubernetes、MongoDB、Elasticsearch、移动端原生 SDK、桌面自动更新和真实云 IAM 控制面；对应检查项按不适用处理。
主动测试前置条件	仅演示动态安全审查的低风险边界：临时依赖安装、临时数据库、loopback 服务、烟测、被动 DAST、响应头和 Cookie 检查。主动破坏性测试需要单独授权。
方法	以前真实项目安全审查报告的结构和版式为原型，但已将审查对象、漏洞类型、代码路径、端点、证据和整改建议全部替换为虚构内容，用于展示 yao-websecurity-skill 的报告交付形态。

字段	值
覆盖台账	示例台账覆盖 V001-V275 共 275 个检查项。虚构项目假设枚举 132 条路由，其中 API 44 条、后台 38 条、Webhook 6 条、导入导出 12 条；示例 SCA 和低级动态检查结果均为演示数据。
假设	这是公开示例报告，不对应真实项目。 所有证据、端点、路径和提交号均为虚构。 评分用于展示模型，不代表任何真实系统风险。

状态分布

安全 157；存在风险 25；存疑 47；不适用 46；未检查 0

状态	数量
安全	157
存在风险	25
存疑	47
不适用	46
未检查	0

P0/P1 与存疑重点

V001 P0 · 对象级授权缺失 BOLA/IDOR

存在风险 / 严重 / 高 / routes/api.php:88

证据： routes/api.php:88；app/Http/Controllers/Api/DocumentDownloadController.php:47；GET /api/workspaces/{workspace}/documents/{document}/download

发现： 文档下载接口只校验 document_id 是否存在，未校验 document.workspace_id 与当前用户 workspace 是否一致；示例动态请求显示跨空间文档返回 200。

根因： 下载控制器缺少对象归属校验，服务层未统一封装 workspace ownership 断言。

影响： 攻击者可枚举或复用文档 ID 读取其他租户私有文件。

修复建议： 在查询层加入 workspace scope；下载前校验成员关系；补充跨租户访问回归测试。

V042 P0 · Webhook 签名验证缺失

存在风险 / 高 / 高 / app/Http/Controllers/Webhook/BillingWebhookController.php:31

证据： app/Http/Controllers/Webhook/BillingWebhookController.php:31；POST /webhooks/billing

发现： 计费 Webhook 直接信任 provider_event_id 和 status 字段，未验证 HMAC 签名和时间戳。

根因： Webhook 接入只做了 JSON schema 校验，没有验证消息来源。

影响： 攻击者可伪造订阅成功、续费失败或退款事件，影响账务与权限。

修复建议： 接入 HMAC 签名、时间戳、nonce 和事件幂等表；拒绝过期或重放事件。

V045 P0 · SQL 注入

存在风险 / 严重 / 高 / app/Repositories/ReportRepository.php:112

证据： app/Repositories/ReportRepository.php:112；GET /api/reports?sort=

发现： 报表列表 sort 参数被拼接进 orderByRaw，未做字段白名单。

根因： 为支持自定义排序直接拼接用户输入。

影响： 攻击者可能构造 SQL 片段读取或破坏报表数据。

修复建议： 将排序字段映射到固定白名单；禁止 raw SQL 拼接；补充 SAST 规则。

V064 P0 · SSRF

存在风险 / 高 / 高 / app/Services/Preview/LinkPreviewService.php:66

证据：app/Services/Preview/LinkPreviewService.php:66；POST /api/link-preview

发现：链接预览服务接受任意 URL 并由服务端请求，示例未发现私网 IP、重定向链和云元数据阻断。

根因：URL 抓取缺少 allowlist、DNS 固定和内网网段拒绝策略。

影响：攻击者可借服务端网络访问内网服务或云元数据端点。

修复建议：增加协议/域名 allowlist、解析后 IP 校验、重定向复核、超时和响应大小限制。

V071 P0 · 路径遍历

存在风险 / 高 / 高 / app/Http/Controllers/ExportDownloadController.php:52

证据：app/Http/Controllers/ExportDownloadController.php:52；GET /exports/download?file=

发现：导出下载接口把 file 参数拼接到 storage_path，示例代码未做路径规范化和根目录限制。

根因：下载接口以文件名作为信任边界。

影响：攻击者可能通过 ../ 读取临时目录或应用配置文件。

修复建议：使用导出记录 ID 查找文件；对路径做 realpath 根目录约束；拒绝绝对路径和 ..。

V077 P0 · 批量赋值 Mass Assignment

存在风险 / 高 / 中 / app/Models/WorkspaceMember.php:18

证据：app/Models/WorkspaceMember.php:18；app/Http/Requests/WorkspaceMemberRequest.php:24

发现：WorkspaceMember 的 fillable 包含 role，邀请接口未限制普通成员提交 owner/admin 角色。

根因：请求校验关注字段类型，未绑定调用者权限矩阵。

影响：低权限成员可能通过批量赋值提升自己或新成员权限。

修复建议：按调用者权限计算可赋予角色；role 从服务端策略生成；为 mass assignment 加 denylist 测试。

V082 P0 · 支付回调伪造

存在风险 / 严重 / 高 / app/Services/Billing/SubscriptionSyncService.php:74

证据：app/Services/Billing/SubscriptionSyncService.php:74；POST /webhooks/billing

发现：订阅状态由 Webhook body 中的 plan/status 直接驱动，缺少金额、币种、订单归属和签名交叉校验。

根因：账务状态机未把第三方事件和本地订单记录做强绑定。

影响：攻击者可能伪造高级套餐或延长订阅。

修复建议：用本地订单号、签名、金额、币种和事件幂等共同校验；状态变更进审计日志。

V083 P0 · 退款流程越权

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V101 P0 · 缓存键缺少用户维度

存在风险 / 高 / 中 / app/Http/Middleware/CacheWorkspaceDashboard.php:37

证据：app/Http/Middleware/CacheWorkspaceDashboard.php:37；GET /api/dashboard

发现：仪表盘缓存 key 只包含 workspace_id，未包含用户角色和数据范围。

根因：缓存层未感知权限维度。

影响：同空间不同角色可能看到不属于自己的敏感指标。

修复建议：缓存 key 加入 user_id/role/scope；敏感数据禁止跨用户缓存。

V127 P0 · 硬编码密钥

存在风险 / 高 / 高 / config/demo-secrets.php

证据: config/demo-secrets.php; docker-compose.example.yml

发现: 示例配置中出现演示 API secret 和对象存储 access key, 占位值形态接近真实密钥且未被启动前校验拒绝。

根因: 示例密钥和真实环境变量边界不清。

影响: 部署者误用示例值会导致服务间认证和对象存储访问被猜测。

修复建议: 改为不可用占位符; 启动时检测默认值并拒绝启动; 接入 secret manager。

V134 P0 · 敏感数据日志泄露

存在风险 / 高 / 中 / app/Exceptions/Handler.php:41

证据: app/Exceptions/Handler.php:41; app/Logging/RequestContextProcessor.php:27

发现: 异常日志记录 Authorization、X-Webhook-Signature 和导出下载 token, 示例脱敏规则未覆盖。

根因: 日志上下文直接透传请求头。

影响: 日志平台或客服排障导出可能泄露可复用凭证。

修复建议: 建立敏感字段黑名单和结构化脱敏; 日志采集前后二次过滤。

V147 P0 · 危险文件上传

存在风险 / 高 / 中 / app/Http/Controllers/AttachmentController.php:63

证据: app/Http/Controllers/AttachmentController.php:63; POST /api/attachments

发现: 附件上传只校验扩展名和 MIME, 未读取魔数, 也未隔离危险格式。

根因: 上传校验依赖客户端可控 Content-Type。

影响: 攻击者可上传伪装脚本或 HTML, 结合预览/下载形成 XSS 或执行风险。

修复建议: 校验魔数; 危险格式强制下载; 上传目录禁执行; 异步 AV/YARA 扫描。

V151 P0 · Zip Slip

存在风险 / 高 / 中 / app/Services/ArchiveImportService.php:91

证据: app/Services/ArchiveImportService.php:91

发现: 压缩包导入直接按 zip entry name 解压到临时目录, 示例未看到 Zip Slip 路径约束。

根因: 解压过程缺少目标路径 realpath 校验。

影响: 恶意压缩包可能覆盖临时目录外文件。

修复建议: 对每个 entry 做规范化和根目录约束; 限制文件数、大小和层级。

V154 P0 · SSRF via 图片/URL 导入

存疑 / 中 / 中

证据: 公开示例未提供足够运行时证据。

发现: 当前证据不足, 需要补充授权测试或部署配置核验。

根因: 示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响: 若真实系统配置不当, 可能形成实际攻击路径。

修复建议: 在真实审查中补充专项动态测试、配置核验和复测证据。

V155 P0 · 公开对象存储桶

存在风险 / 高 / 中 / infra/object-storage-policy.json:12

证据: infra/object-storage-policy.json:12; s3://starbridge-demo-exports/*

发现: 对象存储导出桶示例策略允许匿名 GetObject/ListBucket, 且导出文件名包含可预测日期前缀。

根因: 导出桶策略直接从演示环境复制到生产模板, 缺少 public access block 和最小权限检查。

影响: 攻击者可能枚举并下载租户导出文件或备份文件。

修复建议: 启用 Block Public Access; 导出对象改为短期预签名 URL; 禁止 ListBucket; 增加桶策略 CI 检查。

V158 P0 · 下载接口越权

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V165 P0 · 已知依赖漏洞

存在风险 / 高 / 中 / package-lock.json

证据：package-lock.json；composer.lock

发现：示例依赖扫描假设发现一个高危前端构建依赖仍在可达路径中。

根因：依赖升级和可达性评估未进入发布门禁。

影响：攻击者可能利用已知漏洞影响构建产物或前端运行时。

修复建议：把 SCA 加入 CI 门禁；按 KEV/EPSS 排序升级；记录例外和到期日。

V190 P0 · 安全组 0.0.0.0/0 暴露管理端口

存在风险 / 严重 / 中 / infra/security-groups.tf:24

证据：infra/security-groups.tf:24

发现：示例云安全组把 5432 和 6379 管理端口开放到 0.0.0.0/0。

根因：基础设施模板缺少网络暴露基线检查。

影响：数据库和缓存可能被公网扫描和暴力尝试。

修复建议：仅允许应用子网访问；加云防火墙基线；CI 中加入 IaC 策略检查。

V196 P0 · 云元数据服务 SSRF

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V220 P0 · 数据库公网暴露

存在风险 / 严重 / 中 / infra/security-groups.tf:24

证据：infra/security-groups.tf:24；docker-compose.prod.yml:18

发现：数据库端口在示例生产模板中可公网访问，且没有强制私网绑定。

根因：部署模板把本地调试端口暴露模式带入生产。

影响：攻击者可直接探测数据库认证面。

修复建议：生产模板默认不发布数据库端口；安全组只允许应用服务访问。

V256 P0 · 提示注入

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V258 P0 · 敏感信息泄露

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V261 P0 · RAG 越权检索

存在风险 / 高 / 中 / app/Services/Ai/WorkspaceRetriever.php:52

证据：app/Services/Ai/WorkspaceRetriever.php:52

发现：AI 摘要检索向量库时只按 workspace_id 过滤，未叠加用户文档权限。

根因：RAG 检索层没有复用业务授权矩阵。

影响：用户可能通过 AI 摘要获得无权文档片段。

修复建议：检索前传入用户可见文档 ID；结果返回前再次做 ACL 过滤；记录检索证据。

V019 P1 · CSRF 防护缺失

存在风险 / 高 / 中 / routes/web.php:142

证据：routes/web.php:142；resources/views/settings/security.blade.php；POST /settings/security

发现：安全设置页存在 Cookie 会话状态变更请求，但示例模板未包含 CSRF token，路由也未显式加入 CSRF 中间件。

根因：局部路由组为兼容旧表单关闭了 CSRF 防护。

影响：已登录用户访问恶意页面时可能被诱导修改邮箱、通知或安全设置。

修复建议：恢复 CSRF 中间件；对敏感设置检查 Origin/Referer；为旧表单补 token。

V020 P1 · 权限缓存失效

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V023 P1 · 弱密码策略

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V029 P1 · Cookie 缺少 Secure/HttpOnly/SameSite

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V031 P1 · JWT 过期和撤销缺失

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V056 P1 · XSS 反射型

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V058 P1 · DOM XSS

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V084 P1 · 订单状态跳跃

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V088 P1 · 资源消耗无限制

存在风险 / 中 / 中 / `app/Jobs/GenerateWorkspaceExport.php:29`

证据：`app/Jobs/GenerateWorkspaceExport.php:29`；`POST /api/exports`

发现：导出任务未限制时间范围、行数、并发和队列成本。

根因：异步任务缺少租户级预算和并发限制。

影响：大量导出可耗尽队列与数据库资源。

修复建议：增加租户级导出配额、时间窗口、最大行数、队列并发和取消机制。

V090 P1 · 缺少幂等控制

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V092 P1 · 订阅权限过期后仍可访问

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V098 P1 · Webhook 重放

存在风险 / 中 / 中 / app/Http/Controllers/Webhook/BillingWebhookController.php:44

证据：app/Http/Controllers/Webhook/BillingWebhookController.php:44

发现：Webhook 事件未保存 nonce/timestamp，重复请求可重复触发状态同步。

根因：缺少事件幂等表和重放窗口。

影响：攻击者或网络重试可能造成重复开通、重复退款或状态反复。

修复建议：记录 provider event id、timestamp、signature hash；对已处理事件直接返回。

V102 P1 · 缺失 CSP

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V104 P1 · Clickjacking

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V106 P1 · Token 存储在 localStorage

存在风险 / 中 / 高 / frontend/src/auth/tokenStore.ts:[redacted]

证据：frontend/src/auth/tokenStore.ts:[redacted]

发现：前端把 access_token 持久化到 localStorage，增加 XSS 后令牌被读取的风险。

根因：SPA 采用简单持久化方案，缺少 HttpOnly Cookie 或内存态令牌策略。

影响：一旦发生前端注入，攻击者可长期复用令牌。

修复建议：改用 HttpOnly Secure SameSite Cookie 或短期内存 Token + refresh 轮换。

V110 P1 · postMessage Origin 校验缺失

存在风险 / 中 / 中 / frontend/src/integrations/embedBridge.ts:58

证据：frontend/src/integrations/embedBridge.ts:58

发现：postMessage 处理器未校验 event.origin，仅检查 message.type。

根因：嵌入集成没有来源白名单和消息 schema 校验。

影响：恶意页面可向嵌入窗口发送伪造指令。

修复建议：校验 origin、source、schema 和 nonce；只允许登记的集成域名。

V112 P1 · 浏览器缓存敏感数据

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V122 P1 · TLS 版本或套件过弱

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V128 P1 · 密钥长期不轮换

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V136 P1 · 隐私数据导出无审批

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V138 P1 · 开发测试环境使用真实数据

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V141 P1 · 数据库字段级加密缺失

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V152 P1 · 压缩炸弹

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V153 P1 · 图片处理库漏洞

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V174 P1 · 制品无签名

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V176 P1 · CI 权限过大

存在风险 / 中 / 高 / `.github/workflows/deploy.yml:9`

证据：`.github/workflows/deploy.yml:9`

发现：CI workflow 默认 `permissions: write-all`，并在测试任务中暴露部署环境变量。

根因：流水线权限未按 `job` 最小化。

影响：依赖脚本或 PR 配置错误可能扩大为仓库写入或部署权限。

修复建议：为每个 `job` 显式最小 `permissions`；部署环境加审批；限制 `fork PR secrets`。

V177 P1 · 未固定 GitHub Action 版本

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V181 P1 · 制品到部署缺少不可变性

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V182 P1 · 容器基础镜像过旧

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V184 P1 · 供应商 SDK 权限过大

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V194 P1 · 云日志未开启

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V208 P1 · 容器镜像漏洞

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V221 P1 · 数据库账户权限过大

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V223 P1 · 未启用传输加密

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V225 P1 · 行级安全缺失

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V240 P1 · 安全事件未记录

存在风险 / 中 / 中 / app/Listeners/SecurityEventSubscriber.php

证据：app/Listeners/SecurityEventSubscriber.php

发现：示例未记录对象越权拒绝、Webhook 签名失败、导出下载失败和角色变更事件。

根因：安全事件模型不完整，审计和告警覆盖不足。

影响：入侵或滥用发生后难以及时发现和复盘。

修复建议：定义安全事件清单；集中日志中加入 actor、target、request_id 和结果。

V246 P1 · 超时缺失

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V248 P1 · 备份恢复未演练

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V263 P1 · Embedding 弱隔离

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V267 P1 · 成本型 DoS

存在风险 / 中 / 高 / app/Services/Ai/SummaryJobDispatcher.php:38

证据：app/Services/Ai/SummaryJobDispatcher.php:38；POST /api/ai/summary

发现：AI 摘要任务缺少每租户 token、并发和每日预算限制，低风险动态示例可连续创建任务。

根因：AI 队列只有全局 worker 限制，没有租户级成本控制。

影响：恶意或异常用户可放大模型调用费用并拖慢队列。

修复建议：增加租户级 token 预算、并发限制、上下文长度上限和异常告警。

V273 P1 · 模型输出误导业务决策

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V275 P1 · Agent 审计链缺失

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

详细风险发现

V001 P0 · 对象级授权缺失 BOLA/IDOR

存在风险 / 严重 / 高 / routes/api.php:88

证据: routes/api.php:88; app/Http/Controllers/Api/DocumentDownloadController.php:47; GET /api/workspaces/{workspace}/documents/{document}/download

发现: 文档下载接口只校验 document_id 是否存在, 未校验 document.workspace_id 与当前用户 workspace 是否一致; 示例动态请求显示跨空间文档返回 200。

根因: 下载控制器缺少对象归属校验, 服务层未统一封装 workspace ownership 断言。

影响: 攻击者可枚举或复用文档 ID 读取其他租户私有文件。

修复建议: 在查询层加入 workspace scope; 下载前校验成员关系; 补充跨租户访问回归测试。

V042 P0 · Webhook 签名验证缺失

存在风险 / 高 / 高 / app/Http/Controllers/Webhook/BillingWebhookController.php:31

证据: app/Http/Controllers/Webhook/BillingWebhookController.php:31; POST /webhooks/billing

发现: 计费 Webhook 直接信任 provider_event_id 和 status 字段, 未验证 HMAC 签名和时间戳。

根因: Webhook 接入只做了 JSON schema 校验, 没有验证消息来源。

影响: 攻击者可伪造订阅成功、续费失败或退款事件, 影响账务与权限。

修复建议: 接入 HMAC 签名、时间戳、nonce 和事件幂等表; 拒绝过期或重放事件。

V045 P0 · SQL 注入

存在风险 / 严重 / 高 / app/Repositories/ReportRepository.php:112

证据: app/Repositories/ReportRepository.php:112; GET /api/reports?sort=

发现: 报表列表 sort 参数被拼接进 orderByRaw, 未做字段白名单。

根因: 为支持自定义排序直接拼接用户输入。

影响: 攻击者可能构造 SQL 片段读取或破坏报表数据。

修复建议: 将排序字段映射到固定白名单; 禁止 raw SQL 拼接; 补充 SAST 规则。

V064 P0 · SSRF

存在风险 / 高 / 高 / app/Services/Preview/LinkPreviewService.php:66

证据: app/Services/Preview/LinkPreviewService.php:66; POST /api/link-preview

发现: 链接预览服务接受任意 URL 并由服务端请求, 示例未发现私网 IP、重定向链和云元数据阻断。

根因: URL 抓取缺少 allowlist、DNS 固定和内网网段拒绝策略。

影响: 攻击者可借服务端网络访问内网服务或云元数据端点。

修复建议: 增加协议/域名 allowlist、解析后 IP 校验、重定向复核、超时和响应大小限制。

V071 P0 · 路径遍历

存在风险 / 高 / 高 / app/Http/Controllers/ExportDownloadController.php:52

证据: app/Http/Controllers/ExportDownloadController.php:52; GET /exports/download?file=

发现: 导出下载接口把 file 参数拼接到 storage_path, 示例代码未做路径规范化和根目录限制。

根因: 下载接口以文件名作为信任边界。

影响: 攻击者可能通过 ../ 读取临时目录或应用配置文件。

修复建议: 使用导出记录 ID 查找文件; 对路径做 realpath 根目录约束; 拒绝绝对路径和 ...。

V077 P0 · 批量赋值 Mass Assignment

存在风险 / 高 / 中 / app/Models/WorkspaceMember.php:18

证据: app/Models/WorkspaceMember.php:18; app/Http/Requests/WorkspaceMemberRequest.php:24

发现: WorkspaceMember 的 fillable 包含 role, 邀请接口未限制普通成员提交 owner/admin 角色。

根因: 请求校验关注字段类型, 未绑定调用者权限矩阵。

影响: 低权限成员可能通过批量赋值提升自己或新成员权限。

修复建议: 按调用者权限计算可赋予角色; role 从服务端策略生成; 为 mass assignment 加 denylist 测试。

V082 P0 · 支付回调伪造

存在风险 / 严重 / 高 / app/Services/Billing/SubscriptionSyncService.php:74

证据: app/Services/Billing/SubscriptionSyncService.php:74; POST /webhooks/billing

发现: 订阅状态由 Webhook body 中的 plan/status 直接驱动, 缺少金额、币种、订单归属和签名交叉校验。

根因: 账务状态机未把第三方事件和本地订单记录做强绑定。

影响: 攻击者可能伪造高级套餐或延长订阅。

修复建议: 用本地订单号、签名、金额、币种和事件幂等共同校验; 状态变更进审计日志。

V101 P0 · 缓存键缺少用户维度

存在风险 / 高 / 中 / app/Http/Middleware/CacheWorkspaceDashboard.php:37

证据: app/Http/Middleware/CacheWorkspaceDashboard.php:37; GET /api/dashboard

发现: 仪表盘缓存 key 只包含 workspace_id, 未包含用户角色和数据范围。

根因: 缓存层未感知权限维度。

影响: 同空间不同角色可能看到不属于自己的敏感指标。

修复建议: 缓存 key 加入 user_id/role/scope; 敏感数据禁止跨用户缓存。

V127 P0 · 硬编码密钥

存在风险 / 高 / 高 / config/demo-secrets.php

证据: config/demo-secrets.php; docker-compose.example.yml

发现: 示例配置中出现演示 API secret 和对象存储 access key, 占位值形态接近真实密钥且未被启动前校验拒绝。

根因: 示例密钥和真实环境变量边界不清。

影响: 部署者误用示例值会导致服务间认证和对象存储访问被猜测。

修复建议: 改为不可用占位符; 启动时检测默认值并拒绝启动; 接入 secret manager。

V134 P0 · 敏感数据日志泄露

存在风险 / 高 / 中 / app/Exceptions/Handler.php:41

证据: app/Exceptions/Handler.php:41; app/Logging/RequestContextProcessor.php:27

发现: 异常日志记录 Authorization、X-Webhook-Signature 和导出下载 token, 示例脱敏规则未覆盖。

根因: 日志上下文直接透传请求头。

影响: 日志平台或客服排障导出可能泄露可复用凭证。

修复建议: 建立敏感字段黑名单和结构化脱敏; 日志采集前后二次过滤。

V147 P0 · 危险文件上传

存在风险 / 高 / 中 / app/Http/Controllers/AttachmentController.php:63

证据: app/Http/Controllers/AttachmentController.php:63; POST /api/attachments

发现: 附件上传只校验扩展名和 MIME, 未读取魔数, 也未隔离危险格式。

根因: 上传校验依赖客户端可控 Content-Type。

影响: 攻击者可上传伪装脚本或 HTML, 结合预览/下载形成 XSS 或执行风险。

修复建议: 校验魔数; 危险格式强制下载; 上传目录禁执行; 异步 AV/YARA 扫描。

V151 P0 · Zip Slip

存在风险 / 高 / 中 / app/Services/ArchiveImportService.php:91

证据: app/Services/ArchiveImportService.php:91

发现: 压缩包导入直接按 zip entry name 解压到临时目录, 示例未看到 Zip Slip 路径约束。

根因: 解压过程缺少目标路径 realpath 校验。

影响: 恶意压缩包可能覆盖临时目录外文件。

修复建议: 对每个 entry 做规范化和根目录约束; 限制文件数、大小和层级。

V155 P0 · 公开对象存储桶

存在风险 / 高 / 中 / infra/object-storage-policy.json:12

证据: infra/object-storage-policy.json:12; s3://starbridge-demo-exports/*

发现: 对象存储导出桶示例策略允许匿名 GetObject/ListBucket, 且导出文件名包含可预测日期前缀。

根因: 导出桶策略直接从演示环境复制到生产模板, 缺少 public access block 和最小权限检查。

影响: 攻击者可能枚举并下载租户导出文件或备份文件。

修复建议: 启用 Block Public Access; 导出对象改为短期预签名 URL; 禁止 ListBucket; 增加桶策略 CI 检查。

V165 P0 · 已知依赖漏洞

存在风险 / 高 / 中 / package-lock.json

证据: package-lock.json; composer.lock

发现: 示例依赖扫描假设发现一个高危前端构建依赖仍在可达路径中。

根因: 依赖升级和可达性评估未进入发布门禁。

影响: 攻击者可能利用已知漏洞影响构建产物或前端运行时。

修复建议: 把 SCA 加入 CI 门禁; 按 KEV/EPSS 排序升级; 记录例外和到期日。

V190 P0 · 安全组 0.0.0.0/0 暴露管理端口

存在风险 / 严重 / 中 / infra/security-groups.tf:24

证据: infra/security-groups.tf:24

发现: 示例云安全组把 5432 和 6379 管理端口开放到 0.0.0.0/0。

根因: 基础设施模板缺少网络暴露基线检查。

影响: 数据库和缓存可能被公网扫描和暴力尝试。

修复建议: 仅允许应用子网访问; 加云防火墙基线; CI 中加入 IaC 策略检查。

V220 P0 · 数据库公网暴露

存在风险 / 严重 / 中 / infra/security-groups.tf:24

证据: infra/security-groups.tf:24; docker-compose.prod.yml:18

发现: 数据库端口在示例生产模板中可公网访问, 且没有强制私网绑定。

根因: 部署模板把本地调试端口暴露模式带入生产。

影响: 攻击者可直接探测数据库认证面。

修复建议: 生产模板默认不发布数据库端口; 安全组只允许应用服务访问。

V261 P0 · RAG 越权检索

存在风险 / 高 / 中 / app/Services/Ai/WorkspaceRetriever.php:52

证据: app/Services/Ai/WorkspaceRetriever.php:52

发现: AI 摘要检索向量库时只按 workspace_id 过滤, 未叠加用户文档权限。

根因: RAG 检索层没有复用业务授权矩阵。

影响: 用户可能通过 AI 摘要获得无权文档片段。

修复建议: 检索前传入用户可见文档 ID; 结果返回前再次做 ACL 过滤; 记录检索证据。

V019 P1 · CSRF 防护缺失

存在风险 / 高 / 中 / routes/web.php:142

证据: routes/web.php:142; resources/views/settings/security.blade.php; POST /settings/security

发现: 安全设置页存在 Cookie 会话状态变更请求, 但示例模板未包含 CSRF token, 路由也未显式加入 CSRF 中间件。

根因: 局部路由组为兼容旧表单关闭了 CSRF 防护。

影响: 已登录用户访问恶意页面时可能被诱导修改邮箱、通知或安全设置。

修复建议: 恢复 CSRF 中间件; 对敏感设置检查 Origin/Referer; 为旧表单补 token。

V088 P1 · 资源消耗无限制

存在风险 / 中 / 中 / app/Jobs/GenerateWorkspaceExport.php:29

证据: app/Jobs/GenerateWorkspaceExport.php:29; POST /api/exports

发现: 导出任务未限制时间范围、行数、并发和队列成本。

根因: 异步任务缺少租户级预算和并发限制。

影响: 大量导出可耗尽队列与数据库资源。

修复建议: 增加租户级导出配额、时间窗口、最大行数、队列并发和取消机制。

V098 P1 · Webhook 重放

存在风险 / 中 / 中 / app/Http/Controllers/Webhook/BillingWebhookController.php:44

证据: app/Http/Controllers/Webhook/BillingWebhookController.php:44

发现: Webhook 事件未保存 nonce/timestamp, 重复请求可重复触发状态同步。

根因: 缺少事件幂等表和重放窗口。

影响: 攻击者或网络重试可能造成重复开通、重复退款或状态反复。

修复建议: 记录 provider event id、timestamp、signature hash; 对已处理事件直接返回。

V106 P1 · Token 存储在 localStorage

存在风险 / 中 / 高 / frontend/src/auth/tokenStore.ts:[redacted]

证据: frontend/src/auth/tokenStore.ts:[redacted]

发现: 前端把 access_token 持久化到 localStorage, 增加 XSS 后令牌被读取的风险。

根因: SPA 采用简单持久化方案, 缺少 HttpOnly Cookie 或内存态令牌策略。

影响: 一旦发生前端注入, 攻击者可长期复用令牌。

修复建议: 改用 HttpOnly Secure SameSite Cookie 或短期内存 Token + refresh 轮换。

V110 P1 · postMessage Origin 校验缺失

存在风险 / 中 / 中 / frontend/src/integrations/embedBridge.ts:58

证据: frontend/src/integrations/embedBridge.ts:58

发现: postMessage 处理器未校验 event.origin, 仅检查 message.type。

根因: 嵌入集成没有来源白名单和消息 schema 校验。

影响: 恶意页面可向嵌入窗口发送伪造指令。

修复建议: 校验 origin、source、schema 和 nonce; 只允许登记的集成域名。

V176 P1 · CI 权限过大

存在风险 / 中 / 高 / .github/workflows/deploy.yml:9

证据: .github/workflows/deploy.yml:9

发现: CI workflow 默认 permissions: write-all, 并在测试任务中暴露部署环境变量。

根因: 流水线权限未按 job 最小化。

影响: 依赖脚本或 PR 配置错误可能扩大为仓库写入或部署权限。

修复建议: 为每个 job 显式最小 permissions; 部署环境加审批; 限制 fork PR secrets。

V240 P1 · 安全事件未记录

存在风险 / 中 / 中 / app/Listeners/SecurityEventSubscriber.php

证据：app/Listeners/SecurityEventSubscriber.php

发现：示例未记录对象越权拒绝、Webhook 签名失败、导出下载失败和角色变更事件。

根因：安全事件模型不完整，审计和告警覆盖不足。

影响：入侵或滥用发生后难以及时发现和复盘。

修复建议：定义安全事件清单；集中日志中加入 actor、target、request_id 和结果。

V267 P1 · 成本型 DoS

存在风险 / 中 / 高 / app/Services/Ai/SummaryJobDispatcher.php:38

证据：app/Services/Ai/SummaryJobDispatcher.php:38；POST /api/ai/summary

发现：AI 摘要任务缺少每租户 token、并发和每日预算限制，低风险动态示例可连续创建任务。

根因：AI 队列只有全局 worker 限制，没有租户级成本控制。

影响：恶意或异常用户可放大模型调用费用并拖慢队列。

修复建议：增加租户级 token 预算、并发限制、上下文长度上限和异常告警。

存疑项

V083 P0 · 退款流程越权

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V154 P0 · SSRF via 图片/URL 导入

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V158 P0 · 下载接口越权

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V196 P0 · 云元数据服务 SSRF

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V256 P0 · 提示注入

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V258 P0 · 敏感信息泄露

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V020 P1 · 权限缓存失效

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V023 P1 · 弱密码策略

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V029 P1 · Cookie 缺少 Secure/HttpOnly/SameSite

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V031 P1 · JWT 过期和撤销缺失

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V056 P1 · XSS 反射型

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V058 P1 · DOM XSS

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V084 P1 · 订单状态跳跃

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V090 P1 · 缺少幂等控制

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V092 P1 · 订阅权限过期后仍可访问

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V102 P1 · 缺失 CSP

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V104 P1 · Clickjacking

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V112 P1 · 浏览器缓存敏感数据

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V122 P1 · TLS 版本或套件过弱

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V128 P1 · 密钥长期不轮换

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V136 P1 · 隐私数据导出无审批

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V138 P1 · 开发测试环境使用真实数据

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V141 P1 · 数据库字段级加密缺失

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V152 P1 · 压缩炸弹

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V153 P1 · 图片处理库漏洞

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V174 P1 · 制品无签名

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V177 P1 · 未固定 GitHub Action 版本

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V181 P1 · 制品到部署缺少不可变性

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V182 P1 · 容器基础镜像过旧

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V184 P1 · 供应商 SDK 权限过大

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V194 P1 · 云日志未开启

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V208 P1 · 容器镜像漏洞

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V221 P1 · 数据库账户权限过大

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V223 P1 · 未启用传输加密

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V225 P1 · 行级安全缺失

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V246 P1 · 超时缺失

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V248 P1 · 备份恢复未演练

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V263 P1 · Embedding 弱隔离

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V273 P1 · 模型输出误导业务决策

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V275 P1 · Agent 审计链缺失

存疑 / 中 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V100 P2 · 分页和排序注入

存疑 / 低 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V123 P2 · 缺少 HSTS

存疑 / 低 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V146 P2 · 敏感对象缺少删除和撤销

存疑 / 低 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V162 P2 · 文件病毒扫描缺失

存疑 / 低 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V173 P2 · 未生成 SBOM

存疑 / 低 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V188 P2 · 漏洞库单一来源

存疑 / 低 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

V235 P2 · 缓存穿透和雪崩

存疑 / 低 / 中

证据：公开示例未提供足够运行时证据。

发现：当前证据不足，需要补充授权测试或部署配置核验。

根因：示例报告未包含真实账号矩阵、云配置或生产运行时数据。

影响：若真实系统配置不当，可能形成实际攻击路径。

修复建议：在真实审查中补充专项动态测试、配置核验和复测证据。

未检查项数量：0。若后续加入运行时或主动测试范围，需要补充授权、测试账号、部署 URL 或安全窗口。

残余风险与复测计划

字段	值
残余风险	样例未覆盖真实运行时差异、真实云策略、真实对象存储 ACL、真实模型供应商策略和真实账号矩阵。
复测计划	按 P0/P1 修复后，在隔离临时部署中复测授权矩阵、Webhook 签名、SQL 参数化、URL allowlist、导出路径沙箱、上传处理、CI 权限和 AI 配额控制。

完整评分表摘要

编号	优先级	风险域	检查项	状态	严重性	证据摘要
V001	P0	访问控制、租户隔离与授权	对象级授权缺失 BOLA/IDOR	存在风险	严重	routes/api.php:88； app/Http/Controllers/Api/DocumentDownloadController.php:47；GET /api/workspaces/{workspace}/documents/{document}/download
V002	P0	访问控制、租户隔离与授权	功能级授权缺失 BFLA	安全	中	示例代码审查显示相关路由使用 workspace membership 中间件；未发现该检查项的直接漏洞证据。
V003	P0	访问控制、租户隔离与授权	水平越权	安全	中	示例代码审查显示相关路由使用 workspace membership 中间件；未发现该检查项的直接漏洞证据。
V004	P0	访问控制、租户隔离与授权	垂直越权	安全	中	示例代码审查显示相关路由使用 workspace membership 中间件；未发现该检查项的直接漏洞证据。
V005	P0	访问控制、租户隔离与授权	多租户隔离失效	安全	中	示例代码审查显示相关路由使用 workspace membership 中间件；未发现该检查项的直接漏洞证据。
V006	P1	访问控制、租户隔离与授权	用户可控键导致授权绕过	安全	中	示例代码审查显示相关路由使用 workspace membership 中间件；未发现该检查项的直接漏洞证据。
V007	P1	访问控制、租户隔离与授权	强制浏览和目录枚举	安全	中	示例代码审查显示相关路由使用 workspace membership 中间件；未发现该检查项的直接漏洞证据。
V008	P1	访问控制、租户隔离与授权	缺少默认拒绝策略	安全	中	示例代码审查显示相关路由使用 workspace membership 中间件；未发现该检查项的直接漏洞证据。
V009	P1	访问控制、租户隔离与授权	前端隐藏按钮替代服务端授权	安全	中	示例代码审查显示相关路由使用 workspace membership 中间件；未发现该检查项的直接漏洞证据。
V010	P0	访问控制、租户隔离与授权	导出接口越权	安全	中	示例代码审查显示相关路由使用 workspace membership 中间件；未发现该检查项的直接漏洞证据。
V011	P1	访问控制、租户隔离与授权	批量操作越权	安全	中	示例代码审查显示相关路由使用 workspace membership 中间件；未发现该检查项的直接漏洞证据。
V012	P1	访问控制、租户隔离与授权	workflow 状态越权	安全	中	示例代码审查显示相关路由使用 workspace membership 中间件；未发现该检查项的直接漏洞证据。
V013	P1	访问控制、租户隔离与授权	资源归属只在创建时校验	安全	中	示例代码审查显示相关路由使用 workspace membership 中间件；未发现该检查项的直接漏洞证据。
V014	P1	访问控制、租户隔离与授权	分享链接权限过宽	安全	中	示例代码审查显示相关路由使用 workspace membership 中间件；未发现该检查项的直接漏洞证据。
V015	P1	访问控制、租户隔离与授权	预签名 URL 过期和范围错误	安全	中	示例代码审查显示相关路由使用 workspace membership 中间件；未发现该检查项的直接漏洞证据。
V016	P0	访问控制、租户隔离与授权	内部 API 暴露给公网	安全	中	示例代码审查显示相关路由使用 workspace membership 中间件；未发现该检查项的直接漏洞证据。
V017	P0	访问控制、租户隔离与授权	调试、诊断、管理端点未授权	安全	中	示例代码审查显示相关路由使用 workspace membership 中间件；未发现该检查项的直接漏洞证据。
V018	P1	访问控制、租户隔离与授权	CORS 允许任意来源凭证	安全	中	示例代码审查显示相关路由使用 workspace membership 中间件；未发现该检查项的直接漏洞证据。
V019	P1	访问控制、租户隔离与授权	CSRF 防护缺失	存在风险	高	routes/web.php:142；resources/views/settings/security.blade.php；POST /settings/security
V020	P1	访问控制、租户隔离与授权	权限缓存失效	存疑	中	公开示例未提供足够运行时证据。
V021	P1	访问控制、租户隔离与授权	邀请和成员管理越权	安全	中	示例代码审查显示相关路由使用 workspace membership 中间件；未发现该检查项的直接漏洞证据。
V022	P1	访问控制、租户隔离与授权	服务间调用缺少身份	安全	中	示例代码审查显示相关路由使用 workspace membership 中间件；未发现该检查项的直接漏洞证据。
V023	P1	认证、会话、OAuth/OIDC/SAML	弱密码策略	存疑	中	公开示例未提供足够运行时证据。
V024	P0	认证、会话、OAuth/OIDC/SAML	暴力破解和撞库无防护	安全	中	示例认证流程使用受限登录、短期会话和基础失败审计；未发现该检查项的直接漏洞证据。
V025	P2	认证、会话、OAuth/OIDC/SAML	账号枚举	安全	低	示例认证流程使用受限登录、短期会话和基础失败审计；未发现该检查项的直接漏洞证据。
V026	P0	认证、会话、OAuth/OIDC/SAML	MFA 绕过	安全	中	示例认证流程使用受限登录、短期会话和基础失败审计；未发现该检查项的直接漏洞证据。
V027	P0	认证、会话、OAuth/OIDC/SAML	密码重置链接可猜或不过期	安全	中	示例认证流程使用受限登录、短期会话和基础失败审计；未发现该检查项的直接漏洞证据。
V028	P1	认证、会话、OAuth/OIDC/SAML	会话固定	安全	中	示例认证流程使用受限登录、短期会话和基础失败审计；未发现该检查项的直接漏洞证据。
V029	P1	认证、会话、OAuth/OIDC/SAML	Cookie 缺少 Secure/HttpOnly/SameSite	存疑	中	公开示例未提供足够运行时证据。
V030	P0	认证、会话、OAuth/OIDC/SAML	JWT alg 混淆和 none 风险	安全	中	示例认证流程使用受限登录、短期会话和基础失败审计；未发现该检查项的直接漏洞证据。
V031	P1	认证、会话、OAuth/OIDC/SAML	JWT 过期和撤销缺失	存疑	中	公开示例未提供足够运行时证据。
V032	P0	认证、会话、OAuth/OIDC/SAML	JWT secret 弱或泄露	安全	中	示例认证流程使用受限登录、短期会话和基础失败审计；未发现该检查项的直接漏洞证据。

编号	优先级	风险域	检查项	状态	严重性	证据摘要
V033	P1	认证、会话、OAuth/OIDC/SAML	Refresh Token 重放	安全	中	示例认证流程使用受限登录、短期会话和基础失败审计；未发现该检查项的直接漏洞证据。
V034	P0	认证、会话、OAuth/OIDC/SAML	OAuth redirect_uri 校验不严	不适用		攻击面梳理未发现对应组件或能力。
V035	P1	认证、会话、OAuth/OIDC/SAML	OAuth state/nonce 缺失	不适用		攻击面梳理未发现对应组件或能力。
V036	P0	认证、会话、OAuth/OIDC/SAML	OIDC Token 受众和签发者校验缺失	不适用		攻击面梳理未发现对应组件或能力。
V037	P0	认证、会话、OAuth/OIDC/SAML	SAML 签名包装风险	不适用		攻击面梳理未发现对应组件或能力。
V038	P2	认证、会话、OAuth/OIDC/SAML	登出不彻底	不适用		攻击面梳理未发现对应组件或能力。
V039	P2	认证、会话、OAuth/OIDC/SAML	设备信任绕过	安全	低	示例认证流程使用受限登录、短期会话和基础失败审计；未发现该检查项的直接漏洞证据。
V040	P0	认证、会话、OAuth/OIDC/SAML	管理员默认账号或默认密码	安全	中	示例认证流程使用受限登录、短期会话和基础失败审计；未发现该检查项的直接漏洞证据。
V041	P1	认证、会话、OAuth/OIDC/SAML	API Key 无过期和权限过大	安全	中	示例认证流程使用受限登录、短期会话和基础失败审计；未发现该检查项的直接漏洞证据。
V042	P0	认证、会话、OAuth/OIDC/SAML	Webhook 签名验证缺失	存在风险	高	app/Http/Controllers/Webhook/BillingWebhookController.php:31；POST /webhooks/billing
V043	P1	认证、会话、OAuth/OIDC/SAML	验证码可复用或可绕过	安全	中	示例认证流程使用受限登录、短期会话和基础失败审计；未发现该检查项的直接漏洞证据。
V044	P2	认证、会话、OAuth/OIDC/SAML	会话并发控制缺失	安全	低	示例认证流程使用受限登录、短期会话和基础失败审计；未发现该检查项的直接漏洞证据。
V045	P0	注入、解释器与输入处理	SQL 注入	存在风险	严重	app/Repositories/ReportRepository.php:112；GET /api/reports?sort=
V046	P1	注入、解释器与输入处理	二阶 SQL 注入	安全	中	示例审查未发现对动态解释器、危险拼接或未转义输出路径。
V047	P1	注入、解释器与输入处理	NoSQL 注入	安全	中	示例审查未发现对动态解释器、危险拼接或未转义输出路径。
V048	P1	注入、解释器与输入处理	GraphQL 注入	安全	中	示例审查未发现对动态解释器、危险拼接或未转义输出路径。
V049	P1	注入、解释器与输入处理	LDAP 注入	不适用		攻击面梳理未发现对应组件或能力。
V050	P2	注入、解释器与输入处理	XPath/XML 查询注入	不适用		攻击面梳理未发现对应组件或能力。
V051	P0	注入、解释器与输入处理	OS 命令注入	安全	中	示例审查未发现对动态解释器、危险拼接或未转义输出路径。
V052	P1	注入、解释器与输入处理	参数注入	安全	中	示例审查未发现对动态解释器、危险拼接或未转义输出路径。
V053	P0	注入、解释器与输入处理	代码注入 eval	安全	中	示例审查未发现对动态解释器、危险拼接或未转义输出路径。
V054	P0	注入、解释器与输入处理	模板注入 SSTI	安全	中	示例审查未发现对动态解释器、危险拼接或未转义输出路径。
V055	P0	注入、解释器与输入处理	表达式语言注入	不适用		攻击面梳理未发现对应组件或能力。
V056	P1	注入、解释器与输入处理	XSS 反射型	存疑	中	公开示例未提供足够运行时证据。
V057	P0	注入、解释器与输入处理	XSS 存储型	安全	中	示例审查未发现对动态解释器、危险拼接或未转义输出路径。
V058	P1	注入、解释器与输入处理	DOM XSS	存疑	中	公开示例未提供足够运行时证据。
V059	P1	注入、解释器与输入处理	富文本过滤绕过	安全	中	示例审查未发现对动态解释器、危险拼接或未转义输出路径。
V060	P1	注入、解释器与输入处理	HTTP Header 注入	安全	中	示例审查未发现对动态解释器、危险拼接或未转义输出路径。
V061	P2	注入、解释器与输入处理	日志注入	安全	低	示例审查未发现对动态解释器、危险拼接或未转义输出路径。
V062	P1	注入、解释器与输入处理	邮件头注入	安全	中	示例审查未发现对动态解释器、危险拼接或未转义输出路径。
V063	P0	注入、解释器与输入处理	XXE	不适用		攻击面梳理未发现对应组件或能力。
V064	P0	注入、解释器与输入处理	SSRF	存在风险	高	app/Services/Preview/LinkPreviewService.php:66；POST /api/link-preview
V065	P2	注入、解释器与输入处理	开放重定向	安全	低	示例审查未发现对动态解释器、危险拼接或未转义输出路径。
V066	P0	注入、解释器与输入处理	反序列化	不适用		攻击面梳理未发现对应组件或能力。
V067	P1	注入、解释器与输入处理	YAML 反序列化	不适用		攻击面梳理未发现对应组件或能力。
V068	P1	注入、解释器与输入处理	Prototype Pollution	安全	中	示例审查未发现对动态解释器、危险拼接或未转义输出路径。
V069	P2	注入、解释器与输入处理	Regular Expression DoS	安全	低	示例审查未发现对动态解释器、危险拼接或未转义输出路径。
V070	P1	注入、解释器与输入处理	格式化字符串	不适用		攻击面梳理未发现对应组件或能力。
V071	P0	注入、解释器与输入处理	路径遍历	存在风险	高	app/Http/Controllers/ExportsDownloadController.php:52；GET /exports/download?file=
V072	P0	注入、解释器与输入处理	本地文件包含 LFI	不适用		攻击面梳理未发现对应组件或能力。
V073	P0	注入、解释器与输入处理	远程文件包含 RFI	不适用		攻击面梳理未发现对应组件或能力。
V074	P2	注入、解释器与输入处理	Server-Side Includes 注入	不适用		攻击面梳理未发现对应组件或能力。
V075	P1	注入、解释器与输入处理	GraphQL 复杂度 DoS	不适用		攻击面梳理未发现 GraphQL 服务、schema 或 introspection 端点。
V076	P0	注入、解释器与输入处理	HTTP 请求走私	安全	中	示例审查未发现对动态解释器、危险拼接或未转义输出路径。
V077	P0	API、业务逻辑与滥用	批量赋值 Mass Assignment	存在风险	高	app/Models/WorkspaceMember.php:18；app/Http/Requests/WorkspaceMemberRequest.php:24

编号	优先级	风险域	检查项	状态	严重性	证据摘要
V078	P0	API、业务逻辑与滥用	对象属性级授权缺失	安全	中	示例 API 已有基础 schema 校验和权限中间件；未发现该检查项的直接漏洞证据。
V079	P0	API、业务逻辑与滥用	价格篡改	安全	中	示例 API 已有基础 schema 校验和权限中间件；未发现该检查项的直接漏洞证据。
V080	P1	API、业务逻辑与滥用	优惠券重复使用	安全	中	示例 API 已有基础 schema 校验和权限中间件；未发现该检查项的直接漏洞证据。
V081	P1	API、业务逻辑与滥用	库存和抢购竞态	安全	中	示例 API 已有基础 schema 校验和权限中间件；未发现该检查项的直接漏洞证据。
V082	P0	API、业务逻辑与滥用	支付回调伪造	存在风险	严重	app/Services/Billing/SubscriptionSyncService.php:74；POST /webhooks/billing
V083	P0	API、业务逻辑与滥用	退款流程越权	存疑	中	公开示例未提供足够运行时证据。
V084	P1	API、业务逻辑与滥用	订单状态跳跃	存疑	中	公开示例未提供足够运行时证据。
V085	P1	API、业务逻辑与滥用	短信/邮件轰炸	安全	中	示例 API 已有基础 schema 校验和权限中间件；未发现该检查项的直接漏洞证据。
V086	P2	API、业务逻辑与滥用	注册和邀请滥用	安全	低	示例 API 已有基础 schema 校验和权限中间件；未发现该检查项的直接漏洞证据。
V087	P2	API、业务逻辑与滥用	爬虫和数据抓取	安全	低	示例 API 已有基础 schema 校验和权限中间件；未发现该检查项的直接漏洞证据。
V088	P1	API、业务逻辑与滥用	资源消耗无限制	存在风险	中	app/Jobs/GenerateWorkspaceExport.php:29；POST /api/exports
V089	P2	API、业务逻辑与滥用	无限制 HTTP 方法	安全	低	示例 API 已有基础 schema 校验和权限中间件；未发现该检查项的直接漏洞证据。
V090	P1	API、业务逻辑与滥用	缺少幂等控制	存疑	中	公开示例未提供足够运行时证据。
V091	P1	API、业务逻辑与滥用	业务风控绕过	安全	中	示例 API 已有基础 schema 校验和权限中间件；未发现该检查项的直接漏洞证据。
V092	P1	API、业务逻辑与滥用	订阅权限过期后仍可访问	存疑	中	公开示例未提供足够运行时证据。
V093	P1	API、业务逻辑与滥用	免费额度绕过	安全	中	示例 API 已有基础 schema 校验和权限中间件；未发现该检查项的直接漏洞证据。
V094	P1	API、业务逻辑与滥用	导入任务绕过校验	安全	中	示例 API 已有基础 schema 校验和权限中间件；未发现该检查项的直接漏洞证据。
V095	P2	API、业务逻辑与滥用	GraphQL introspection 暴露	不适用		攻击面梳理未发现对应组件或能力。
V096	P2	API、业务逻辑与滥用	Schema 漂移	安全	低	示例 API 已有基础 schema 校验和权限中间件；未发现该检查项的直接漏洞证据。
V097	P1	API、业务逻辑与滥用	API 版本未退役	安全	中	示例 API 已有基础 schema 校验和权限中间件；未发现该检查项的直接漏洞证据。
V098	P1	API、业务逻辑与滥用	Webhook 重放	存在风险	中	app/Http/Controllers/Webhook/BillingWebhookController.php:44
V099	P1	API、业务逻辑与滥用	第三方 API 过度信任	安全	中	示例 API 已有基础 schema 校验和权限中间件；未发现该检查项的直接漏洞证据。
V100	P2	API、业务逻辑与滥用	分页和排序注入	存疑	低	公开示例未提供足够运行时证据。
V101	P0	API、业务逻辑与滥用	缓存键缺少用户维度	存在风险	高	app/Http/Middleware/CacheWorkspaceDashboard.php:37；GET /api/dashboard
V102	P1	前端、浏览器与客户端	缺失 CSP	存疑	中	公开示例未提供足够运行时证据。
V103	P2	前端、浏览器与客户端	CSP 过宽	安全	低	示例前端构建产物和响应头未发现该检查项的直接风险证据。
V104	P1	前端、浏览器与客户端	Clickjacking	存疑	中	公开示例未提供足够运行时证据。
V105	P2	前端、浏览器与客户端	Source Map 泄露	安全	低	示例前端构建产物和响应头未发现该检查项的直接风险证据。
V106	P1	前端、浏览器与客户端	Token 存储在 localStorage	存在风险	中	frontend/src/auth/tokenStore.ts:[redacted]
V107	P1	前端、浏览器与客户端	前端环境变量泄露	安全	中	示例前端构建产物和响应头未发现该检查项的直接风险证据。
V108	P1	前端、浏览器与客户端	第三方脚本供应链	安全	中	示例前端构建产物和响应头未发现该检查项的直接风险证据。
V109	P2	前端、浏览器与客户端	缺少 SRI	安全	低	示例前端构建产物和响应头未发现该检查项的直接风险证据。
V110	P1	前端、浏览器与客户端	postMessage Origin 校验缺失	存在风险	中	frontend/src/integrations/embedBridge.ts:58
V111	P2	前端、浏览器与客户端	Service Worker 范围过宽	安全	低	示例前端构建产物和响应头未发现该检查项的直接风险证据。
V112	P1	前端、浏览器与客户端	浏览器缓存敏感数据	存疑	中	公开示例未提供足够运行时证据。
V113	P2	前端、浏览器与客户端	剪贴板和下载内容注入	安全	低	示例前端构建产物和响应头未发现该检查项的直接风险证据。
V114	P3	前端、浏览器与客户端	开放跨域字体/资源导致信息泄露	安全	低	示例前端构建产物和响应头未发现该检查项的直接风险证据。
V115	P0	前端、浏览器与客户端	WebSocket 鉴权缺失	安全	中	示例前端构建产物和响应头未发现该检查项的直接风险证据。
V116	P1	前端、浏览器与客户端	WebSocket 消息级授权缺失	安全	中	示例前端构建产物和响应头未发现该检查项的直接风险证据。
V117	P1	前端、浏览器与客户端	客户端路由守卫绕过	安全	中	示例前端构建产物和响应头未发现该检查项的直接风险证据。
V118	P2	前端、浏览器与客户端	敏感信息出现在 HTML 注释	安全	低	示例前端构建产物和响应头未发现该检查项的直接风险证据。
V119	P2	前端、浏览器与客户端	静态配置暴露内部域名	安全	低	示例前端构建产物和响应头未发现该检查项的直接风险证据。
V120	P2	前端、浏览器与客户端	iframe sandbox 配置不当	安全	低	示例前端构建产物和响应头未发现该检查项的直接风险证据。
V121	P1	前端、浏览器与客户端	前端依赖漏洞	安全	中	示例前端构建产物和响应头未发现该检查项的直接风险证据。

编号	优先级	风险域	检查项	状态	严重性	证据摘要
V122	P1	加密、密钥、隐私与数据保护	TLS 版本或套件过弱	存疑	中	公开示例未提供足够运行时证据。
V123	P2	加密、密钥、隐私与数据保护	缺少 HSTS	存疑	低	公开示例未提供足够运行时证据。
V124	P0	加密、密钥、隐私与数据保护	证书验证关闭	安全	中	示例配置采用标准哈希和基础脱敏策略；未发现该检查项的直接漏洞证据。
V125	P0	加密、密钥、隐私与数据保护	明文传输敏感数据	安全	中	示例配置采用标准哈希和基础脱敏策略；未发现该检查项的直接漏洞证据。
V126	P0	加密、密钥、隐私与数据保护	密码哈希弱	安全	中	示例配置采用标准哈希和基础脱敏策略；未发现该检查项的直接漏洞证据。
V127	P0	加密、密钥、隐私与数据保护	硬编码密钥	存在风险	高	config/demo-secrets.php； docker-compose.example.yml
V128	P1	加密、密钥、隐私与数据保护	密钥长期不轮换	存疑	中	公开示例未提供足够运行时证据。
V129	P0	加密、密钥、隐私与数据保护	默认密钥或示例密钥	安全	中	示例配置采用标准哈希和基础脱敏策略；未发现该检查项的直接漏洞证据。
V130	P1	加密、密钥、隐私与数据保护	加密密钥和密文同库存储	安全	中	示例配置采用标准哈希和基础脱敏策略；未发现该检查项的直接漏洞证据。
V131	P0	加密、密钥、隐私与数据保护	弱随机数	安全	中	示例配置采用标准哈希和基础脱敏策略；未发现该检查项的直接漏洞证据。
V132	P0	加密、密钥、隐私与数据保护	使用 MD5/SHA1 存储密码或签名	安全	中	示例配置采用标准哈希和基础脱敏策略；未发现该检查项的直接漏洞证据。
V133	P1	加密、密钥、隐私与数据保护	对称加密模式错误	安全	中	示例配置采用标准哈希和基础脱敏策略；未发现该检查项的直接漏洞证据。
V134	P0	加密、密钥、隐私与数据保护	敏感数据日志泄露	存在风险	高	app/Exceptions/Handler.php:41； app/Logging/RequestContextProcessor.php:27
V135	P2	加密、密钥、隐私与数据保护	PII 过度收集	安全	低	示例配置采用标准哈希和基础脱敏策略；未发现该检查项的直接漏洞证据。
V136	P1	加密、密钥、隐私与数据保护	隐私数据导出无审批	存疑	中	公开示例未提供足够运行时证据。
V137	P1	加密、密钥、隐私与数据保护	备份未加密	安全	中	示例配置采用标准哈希和基础脱敏策略；未发现该检查项的直接漏洞证据。
V138	P1	加密、密钥、隐私与数据保护	开发测试环境使用真实数据	存疑	中	公开示例未提供足够运行时证据。
V139	P2	加密、密钥、隐私与数据保护	日志保留过长或无删除机制	安全	低	示例配置采用标准哈希和基础脱敏策略；未发现该检查项的直接漏洞证据。
V140	P2	加密、密钥、隐私与数据保护	跨境/第三方数据流未登记	安全	低	示例配置采用标准哈希和基础脱敏策略；未发现该检查项的直接漏洞证据。
V141	P1	加密、密钥、隐私与数据保护	数据库字段级加密缺失	存疑	中	公开示例未提供足够运行时证据。
V142	P1	加密、密钥、隐私与数据保护	Secret Manager 权限过宽	安全	中	示例配置采用标准哈希和基础脱敏策略；未发现该检查项的直接漏洞证据。
V143	P1	加密、密钥、隐私与数据保护	密钥出现在崩溃报告	安全	中	示例配置采用标准哈希和基础脱敏策略；未发现该检查项的直接漏洞证据。
V144	P1	加密、密钥、隐私与数据保护	Token 出现在 URL	安全	中	示例配置采用标准哈希和基础脱敏策略；未发现该检查项的直接漏洞证据。
V145	P0	加密、密钥、隐私与数据保护	会话标识可预测	安全	中	示例配置采用标准哈希和基础脱敏策略；未发现该检查项的直接漏洞证据。
V146	P2	加密、密钥、隐私与数据保护	敏感对象缺少删除和撤销	存疑	低	公开示例未提供足够运行时证据。
V147	P0	文件、对象存储、媒体处理	危险文件上传	存在风险	高	app/Http/Controllers/AttachmentController.php:63； POST /api/attachments
V148	P0	文件、对象存储、媒体处理	上传后可执行	安全	中	示例文件服务在该检查项上具备基础隔离或未暴露对应能力。
V149	P1	文件、对象存储、媒体处理	MIME 嗅探导致 XSS	安全	中	示例文件服务在该检查项上具备基础隔离或未暴露对应能力。
V150	P0	文件、对象存储、媒体处理	文件名路径遍历	安全	中	示例文件服务在该检查项上具备基础隔离或未暴露对应能力。
V151	P0	文件、对象存储、媒体处理	Zip Slip	存在风险	高	app/Services/ArchiveImportService.php:91
V152	P1	文件、对象存储、媒体处理	压缩炸弹	存疑	中	公开示例未提供足够运行时证据。
V153	P1	文件、对象存储、媒体处理	图片处理库漏洞	存疑	中	公开示例未提供足够运行时证据。
V154	P0	文件、对象存储、媒体处理	SSRF via 图片/URL 导入	存疑	中	公开示例未提供足够运行时证据。
V155	P0	文件、对象存储、媒体处理	公开对象存储桶	存在风险	高	infra/object-storage-policy.json:12； s3://starbridge-demo-exports/*
V156	P1	文件、对象存储、媒体处理	对象存储可列目录	安全	中	示例文件服务在该检查项上具备基础隔离或未暴露对应能力。
V157	P0	文件、对象存储、媒体处理	预览服务读取任意文件	安全	中	示例文件服务在该检查项上具备基础隔离或未暴露对应能力。
V158	P0	文件、对象存储、媒体处理	下载接口越权	存疑	中	公开示例未提供足够运行时证据。
V159	P2	文件、对象存储、媒体处理	临时文件未清理	安全	低	示例文件服务在该检查项上具备基础隔离或未暴露对应能力。

编号	优先级	风险域	检查项	状态	严重性	证据摘要
V160	P0	文件、对象存储、媒体处理	公开备份文件	安全	中	示例文件服务在该检查项上具备基础隔离或未暴露对应能力。
V161	P0	文件、对象存储、媒体处理	源代码包暴露	安全	中	示例文件服务在该检查项上具备基础隔离或未暴露对应能力。
V162	P2	文件、对象存储、媒体处理	文件病毒扫描缺失	存疑	低	公开示例未提供足够运行时证据。
V163	P2	文件、对象存储、媒体处理	导出文件无水印和审计	安全	低	示例文件服务在该检查项上具备基础隔离或未暴露对应能力。
V164	P1	文件、对象存储、媒体处理	跨租户文件 key 可预测	安全	中	示例文件服务在该检查项上具备基础隔离或未暴露对应能力。
V165	P0	供应链、依赖、构建与 CI/CD	已知依赖漏洞	存在风险	高	package-lock.json；composer.lock
V166	P1	供应链、依赖、构建与 CI/CD	传递依赖漏洞	安全	中	示例 lockfile 和流水线检查未发现该检查项的直接风险证据。
V167	P1	供应链、依赖、构建与 CI/CD	未维护组件	安全	中	示例 lockfile 和流水线检查未发现该检查项的直接风险证据。
V168	P0	供应链、依赖、构建与 CI/CD	依赖混淆	安全	中	示例 lockfile 和流水线检查未发现该检查项的直接风险证据。
V169	P1	供应链、依赖、构建与 CI/CD	Typosquatting 包	安全	中	示例 lockfile 和流水线检查未发现该检查项的直接风险证据。
V170	P1	供应链、依赖、构建与 CI/CD	恶意 postinstall 脚本	安全	中	示例 lockfile 和流水线检查未发现该检查项的直接风险证据。
V171	P1	供应链、依赖、构建与 CI/CD	未提交 lockfile	安全	中	示例 lockfile 和流水线检查未发现该检查项的直接风险证据。
V172	P2	供应链、依赖、构建与 CI/CD	依赖版本过宽	安全	低	示例 lockfile 和流水线检查未发现该检查项的直接风险证据。
V173	P2	供应链、依赖、构建与 CI/CD	未生成 SBOM	存疑	低	公开示例未提供足够运行时证据。
V174	P1	供应链、依赖、构建与 CI/CD	制品无签名	存疑	中	公开示例未提供足够运行时证据。
V175	P0	供应链、依赖、构建与 CI/CD	CI/CD 密钥泄露	安全	中	示例 lockfile 和流水线检查未发现该检查项的直接风险证据。
V176	P1	供应链、依赖、构建与 CI/CD	CI 权限过大	存在风险	中	.github/workflows/deploy.yml:9
V177	P1	供应链、依赖、构建与 CI/CD	未固定 GitHub Action 版本	存疑	中	公开示例未提供足够运行时证据。
V178	P0	供应链、依赖、构建与 CI/CD	Pull Request 可访问生产密钥	安全	中	示例 lockfile 和流水线检查未发现该检查项的直接风险证据。
V179	P0	供应链、依赖、构建与 CI/CD	构建环境可被篡改	安全	中	示例 lockfile 和流水线检查未发现该检查项的直接风险证据。
V180	P0	供应链、依赖、构建与 CI/CD	制品仓库公开	安全	中	示例 lockfile 和流水线检查未发现该检查项的直接风险证据。
V181	P1	供应链、依赖、构建与 CI/CD	制品到部署缺少不可变性	存疑	中	公开示例未提供足够运行时证据。
V182	P1	供应链、依赖、构建与 CI/CD	容器基础镜像过旧	存疑	中	公开示例未提供足够运行时证据。
V183	P0	供应链、依赖、构建与 CI/CD	镜像包含构建密钥	安全	中	示例 lockfile 和流水线检查未发现该检查项的直接风险证据。
V184	P1	供应链、依赖、构建与 CI/CD	供应商 SDK 权限过大	存疑	中	公开示例未提供足够运行时证据。
V185	P0	供应链、依赖、构建与 CI/CD	自动更新通道未校验	不适用		攻击面梳理未发现对应组件或能力。
V186	P1	供应链、依赖、构建与 CI/CD	CDN 资源被替换风险	安全	中	示例 lockfile 和流水线检查未发现该检查项的直接风险证据。
V187	P3	供应链、依赖、构建与 CI/CD	许可证和合规风险	不适用		攻击面梳理未发现对应组件或能力。
V188	P2	供应链、依赖、构建与 CI/CD	漏洞库单一来源	存疑	低	公开示例未提供足够运行时证据。
V189	P1	供应链、依赖、构建与 CI/CD	补丁回归验证缺失	安全	中	示例 lockfile 和流水线检查未发现该检查项的直接风险证据。
V190	P0	云、容器、Kubernetes、IaC 与网络	安全组 0.0.0.0/0 暴露管理端口	存在风险	严重	infra/security-groups.tf:24
V191	P1	云、容器、Kubernetes、IaC 与网络	云 IAM 权限过宽	不适用		攻击面梳理未发现对应组件或能力。
V192	P0	云、容器、Kubernetes、IaC 与网络	未启用 MFA	不适用		攻击面梳理未发现对应组件或能力。
V193	P0	云、容器、Kubernetes、IaC 与网络	对象存储公开读写	安全	中	示例部署基线未发现该检查项的直接暴露证据。
V194	P1	云、容器、Kubernetes、IaC 与网络	云日志未开启	存疑	中	公开示例未提供足够运行时证据。

编号	优先级	风险域	检查项	状态	严重性	证据摘要
V195	P1	云、容器、Kubernetes、IaC 与网络	KMS 未使用或权限过宽	安全	中	示例部署基线未发现该检查项的直接暴露证据。
V196	P0	云、容器、Kubernetes、IaC 与网络	云元数据服务 SSRF	存疑	中	公开示例未提供足够运行时证据。
V197	P0	云、容器、Kubernetes、IaC 与网络	Terraform state 泄露	不适用		攻击面梳理未发现对应组件或能力。
V198	P0	云、容器、Kubernetes、IaC 与网络	IaC 硬编码密钥	安全	中	示例部署基线未发现该检查项的直接暴露证据。
V199	P2	云、容器、Kubernetes、IaC 与网络	Docker 以 root 运行	安全	低	示例部署基线未发现该检查项的直接暴露证据。
V200	P0	云、容器、Kubernetes、IaC 与网络	特权容器	不适用		攻击面梳理未发现对应组件或能力。
V201	P0	云、容器、Kubernetes、IaC 与网络	挂载 Docker socket	不适用		攻击面梳理未发现对应组件或能力。
V202	P0	云、容器、Kubernetes、IaC 与网络	hostPath 危险挂载	不适用		攻击面梳理未发现对应组件或能力。
V203	P1	云、容器、Kubernetes、IaC 与网络	Kubernetes RBAC 过宽	不适用		攻击面梳理未发现对应组件或能力。
V204	P2	云、容器、Kubernetes、IaC 与网络	默认 ServiceAccount 自动挂载	不适用		攻击面梳理未发现对应组件或能力。
V205	P1	云、容器、Kubernetes、IaC 与网络	Kubernetes Secret 明文风险	不适用		攻击面梳理未发现对应组件或能力。
V206	P1	云、容器、Kubernetes、IaC 与网络	Ingress 误配	不适用		攻击面梳理未发现对应组件或能力。
V207	P1	云、容器、Kubernetes、IaC 与网络	NetworkPolicy 缺失	不适用		攻击面梳理未发现对应组件或能力。
V208	P1	云、容器、Kubernetes、IaC 与网络	容器镜像漏洞	存疑	中	公开示例未提供足够运行时证据。
V209	P2	云、容器、Kubernetes、IaC 与网络	镜像未固定 digest	安全	低	示例部署基线未发现该检查项的直接暴露证据。
V210	P1	云、容器、Kubernetes、IaC 与网络	Pod 缺少资源限制	不适用		攻击面梳理未发现对应组件或能力。
V211	P0	云、容器、Kubernetes、IaC 与网络	公网负载均衡暴露内部服务	安全	中	示例部署基线未发现该检查项的直接暴露证据。
V212	P2	云、容器、Kubernetes、IaC 与网络	WAF 规则缺失或旁路	安全	低	示例部署基线未发现该检查项的直接暴露证据。
V213	P1	云、容器、Kubernetes、IaC 与网络	DNS 接管	不适用		攻击面梳理未发现对应组件或能力。
V214	P2	云、容器、Kubernetes、IaC 与网络	域名和证书过期	不适用		攻击面梳理未发现对应组件或能力。
V215	P2	云、容器、Kubernetes、IaC 与网络	邮件域名安全缺失	不适用		攻击面梳理未发现对应组件或能力。
V216	P1	云、容器、Kubernetes、IaC 与网络	CDN 源站直连	安全	中	示例部署基线未发现该检查项的直接暴露证据。
V217	P0	云、容器、Kubernetes、IaC 与网络	备份账户和灾备环境暴露	不适用		攻击面梳理未发现对应组件或能力。
V218	P1	云、容器、Kubernetes、IaC 与网络	跨账号信任过宽	不适用		攻击面梳理未发现对应组件或能力。
V219	P1	云、容器、Kubernetes、IaC 与网络	边缘函数权限过大	不适用		攻击面梳理未发现对应组件或能力。
V220	P0	数据库、缓存、搜索、队列	数据库公网暴露	存在风险	严重	infra/security-groups.tf:24; docker-compose.prod.yml:18
V221	P1	数据库、缓存、搜索、队列	数据库账户权限过大	存疑	中	公开示例未提供足够运行时证据。
V222	P0	数据库、缓存、搜索、队列	数据库弱口令	安全	中	示例数据库/缓存访问通过应用服务封装；未发现该检查项的直接漏洞证据。
V223	P1	数据库、缓存、搜索、队列	未启用传输加密	存疑	中	公开示例未提供足够运行时证据。
V224	P0	数据库、缓存、搜索、队列	备份文件泄露	安全	中	示例数据库/缓存访问通过应用服务封装；未发现该检查项的直接漏洞证据。
V225	P1	数据库、缓存、搜索、队列	行级安全缺失	存疑	中	公开示例未提供足够运行时证据。
V226	P1	数据库、缓存、搜索、队列	存储过程注入	安全	中	示例数据库/缓存访问通过应用服务封装；未发现该检查项的直接漏洞证据。
V227	P0	数据库、缓存、搜索、队列	Redis 未授权	安全	中	示例数据库/缓存访问通过应用服务封装；未发现该检查项的直接漏洞证据。
V228	P1	数据库、缓存、搜索、队列	Redis 危险命令	安全	中	示例数据库/缓存访问通过应用服务封装；未发现该检查项的直接漏洞证据。
V229	P0	数据库、缓存、搜索、队列	MongoDB 未授权	不适用		攻击面梳理未发现对应组件或能力。
V230	P0	数据库、缓存、搜索、队列	Elasticsearch 索引公开	不适用		攻击面梳理未发现对应组件或能力。
V231	P1	数据库、缓存、搜索、队列	搜索结果越权	安全	中	示例数据库/缓存访问通过应用服务封装；未发现该检查项的直接漏洞证据。
V232	P0	数据库、缓存、搜索、队列	消息队列未授权	不适用		攻击面梳理未发现对应组件或能力。
V233	P1	数据库、缓存、搜索、队列	队列消息包含敏感数据	安全	中	示例数据库/缓存访问通过应用服务封装；未发现该检查项的直接漏洞证据。

编号	优先级	风险域	检查项	状态	严重性	证据摘要
V234	P1	数据库、缓存、搜索、队列	任务队列反序列化	不适用		攻击面梳理未发现对应组件或能力。
V235	P2	数据库、缓存、搜索、队列	缓存穿透和雪崩	存疑	低	公开示例未提供足够运行时证据。
V236	P2	数据库、缓存、搜索、队列	数据库审计缺失	安全	低	示例数据库/缓存访问通过应用服务封装；未发现该检查项的直接漏洞证据。
V237	P2	数据库、缓存、搜索、队列	影子数据存储	安全	低	示例数据库/缓存访问通过应用服务封装；未发现该检查项的直接漏洞证据。
V238	P1	错误处理、日志、监控、韧性	错误堆栈泄露	安全	中	示例错误处理和日志配置在该项上未发现直接风险证据。
V239	P0	错误处理、日志、监控、韧性	调试模式开启	安全	中	示例错误处理和日志配置在该项上未发现直接风险证据。
V240	P1	错误处理、日志、监控、韧性	安全事件未记录	存在风险	中	app/Listeners/SecurityEventSubscriber.php
V241	P2	错误处理、日志、监控、韧性	日志缺少关联 ID	安全	低	示例错误处理和日志配置在该项上未发现直接风险证据。
V242	P1	错误处理、日志、监控、韧性	日志可被普通用户篡改	安全	中	示例错误处理和日志配置在该项上未发现直接风险证据。
V243	P2	错误处理、日志、监控、韧性	告警阈值缺失	安全	低	示例错误处理和日志配置在该项上未发现直接风险证据。
V244	P2	错误处理、日志、监控、韧性	安全扫描未触发告警	安全	低	示例错误处理和日志配置在该项上未发现直接风险证据。
V245	P0	错误处理、日志、监控、韧性	异常处理失败开放	安全	中	示例错误处理和日志配置在该项上未发现直接风险证据。
V246	P1	错误处理、日志、监控、韧性	超时缺失	存疑	中	公开示例未提供足够运行时证据。
V247	P2	错误处理、日志、监控、韧性	重试风暴	安全	低	示例错误处理和日志配置在该项上未发现直接风险证据。
V248	P1	错误处理、日志、监控、韧性	备份恢复未演练	存疑	中	公开示例未提供足够运行时证据。
V249	P2	错误处理、日志、监控、韧性	删除保护缺失	安全	低	示例错误处理和日志配置在该项上未发现直接风险证据。
V250	P2	错误处理、日志、监控、韧性	速率限制只按 IP	安全	低	示例错误处理和日志配置在该项上未发现直接风险证据。
V251	P2	错误处理、日志、监控、韧性	异常流量未隔离	安全	低	示例错误处理和日志配置在该项上未发现直接风险证据。
V252	P2	错误处理、日志、监控、韧性	健康检查泄露	安全	低	示例错误处理和日志配置在该项上未发现直接风险证据。
V253	P1	错误处理、日志、监控、韧性	指标端点暴露	安全	中	示例错误处理和日志配置在该项上未发现直接风险证据。
V254	P0	错误处理、日志、监控、韧性	审计日志包含密钥	安全	中	示例错误处理和日志配置在该项上未发现直接风险证据。
V255	P1	错误处理、日志、监控、韧性	异常回滚不一致	安全	中	示例错误处理和日志配置在该项上未发现直接风险证据。
V256	P0	AI、LLM、RAG 与智能体应用	提示注入	存疑	中	公开示例未提供足够运行时证据。
V257	P0	AI、LLM、RAG 与智能体应用	间接提示注入	安全	中	示例 AI 能力在该项上未发现直接越权或泄露证据。
V258	P0	AI、LLM、RAG 与智能体应用	敏感信息泄露	存疑	中	公开示例未提供足够运行时证据。
V259	P2	AI、LLM、RAG 与智能体应用	系统提示泄露	安全	低	示例 AI 能力在该项上未发现直接越权或泄露证据。
V260	P0	AI、LLM、RAG 与智能体应用	工具调用过度代理	安全	中	示例 AI 能力在该项上未发现直接越权或泄露证据。
V261	P0	AI、LLM、RAG 与智能体应用	RAG 越权检索	存在风险	高	app/Services/Ai/WorkspaceRetriever.php:52
V262	P1	AI、LLM、RAG 与智能体应用	向量库投毒	安全	中	示例 AI 能力在该项上未发现直接越权或泄露证据。
V263	P1	AI、LLM、RAG 与智能体应用	Embedding 弱隔离	存疑	中	公开示例未提供足够运行时证据。
V264	P1	AI、LLM、RAG 与智能体应用	模型供应链风险	安全	中	示例 AI 能力在该项上未发现直接越权或泄露证据。
V265	P0	AI、LLM、RAG 与智能体应用	输出未净化导致 XSS	安全	中	示例 AI 能力在该项上未发现直接越权或泄露证据。
V266	P0	AI、LLM、RAG 与智能体应用	代码生成直接执行	安全	中	示例 AI 能力在该项上未发现直接越权或泄露证据。
V267	P1	AI、LLM、RAG 与智能体应用	成本型 DoS	存在风险	中	app/Services/Ai/SummaryJobDispatcher.php:38；POST /api/ai/summary
V268	P0	AI、LLM、RAG 与智能体应用	越权读取用户邮箱/文件	不适用		攻击面梳理未发现对应组件或能力。

编号	优先级	风险域	检查项	状态	严重性	证据摘要
V269	P0	AI、LLM、RAG 与智能体应用	插件回调 SSRF	安全	中	示例 AI 能力在该项上未发现直接越权或泄露证据。
V270	P1	AI、LLM、RAG 与智能体应用	训练/微调数据污染	不适用		攻击面梳理未发现对应组件或能力。
V271	P1	AI、LLM、RAG 与智能体应用	越权记忆	不适用		攻击面梳理未发现对应组件或能力。
V272	P2	AI、LLM、RAG 与智能体应用	安全分类器绕过	不适用		攻击面梳理未发现对应组件或能力。
V273	P1	AI、LLM、RAG 与智能体应用	模型输出误导业务决策	存疑	中	公开示例未提供足够运行时证据。
V274	P1	AI、LLM、RAG 与智能体应用	提示和上下文进入第三方供应商	不适用		攻击面梳理未发现对应组件或能力。
V275	P1	AI、LLM、RAG 与智能体应用	Agent 审计链缺失	存疑	中	公开示例未提供足够运行时证据。